

Week 2 Portfolio Project Deliverable

Security Architecture, STRIDE Threat Modeling & Compliance Automation

PaySphere Merchant Portal

Learning Track: Governance, Risk & Compliance (GRC) Analyst

Week: 2

Project Type: Security Threat Modeling and Compliance Control Analysis

Executive Summary

This Week 2 project applies foundational cybersecurity and GRC concepts to a realistic fintech environment: **PaySphere**, a payment-processing company operating a merchant portal for businesses to view transactions, process refunds, and manage settlements.

The merchant portal was previously identified as a critical risk area under **PSR-007: Web Application Security Vulnerabilities, Merchant Portal**. The purpose of this project was to analyze the portal from both a **security threat perspective** and a **GRC/compliance operations perspective**.

The project was divided into two parts:

- **Project A:** Develop a STRIDE threat model for the PaySphere merchant portal.
- **Project B:** Map selected security controls into the structure of a compliance automation platform.

The final outcome demonstrates the ability to move through a practical GRC workflow:

Business System → Threat Identification → Security Impact → Control Selection → Evidence Collection → Ongoing Compliance Monitoring

1. Business and System Context

PaySphere is a Series B fintech company providing payment processing capabilities and a merchant portal for businesses. The merchant portal allows authorized merchants to:

- View transactions.
- Process refunds.
- Manage settlements.
- Interact with payment-related information.

The company operates in a high-risk environment due to the sensitivity and criticality of payment and customer information.

The merchant portal was identified as a critical system because vulnerabilities affecting the application could expose sensitive information, affect transaction integrity, disrupt payment operations, or allow unauthorized access.

Key Security Considerations

The environment includes several security-sensitive assets:

- Customer KYC information.
- Payment and transaction data.
- Merchant information.
- Refund functionality.
- Payment gateway integrations.
- Privileged administrative access.
- Production systems and databases.

Because the merchant portal directly interacts with sensitive financial processes, security failures can result in operational disruption, financial loss, unauthorized data disclosure, regulatory exposure, and reputational damage.

2. Project Objectives

The objectives of this project were to:

1. Apply the STRIDE threat modeling framework to the PaySphere merchant portal.
 2. Identify one realistic threat under each STRIDE category.
 3. Map each threat to the CIA Triad or Parkerian Hexad security property it primarily affects.
 4. Identify an appropriate security control to mitigate each threat.
 5. Demonstrate how selected controls could be represented within a compliance automation platform.
 6. Identify the type of evidence required to demonstrate control effectiveness.
 7. Distinguish between continuously monitored and periodically recurring controls.
-

Part A — STRIDE Threat Model

3. STRIDE Methodology

STRIDE is a threat-modeling framework used to systematically identify different categories of security threats.

The six categories are:

Category	Security Question
Spoofing	Can someone pretend to be another user, system, or service?
Tampering	Can information or system data be modified without authorization?
Repudiation	Can an actor deny performing an action?
Information Disclosure	Can sensitive information be exposed to unauthorized parties?
Denial of Service	Can legitimate users be prevented from accessing the system?
Elevation of Privilege	Can a user gain permissions beyond their authorized level?

The framework was applied specifically to the PaySphere merchant portal.

4. STRIDE Threat Model Summary

STRIDE Category	Threat Scenario	Security Pillar Impacted	Primary Control
Spoofing	Fake Razorpay webhook impersonates the legitimate payment gateway	Authenticity	Cryptographic webhook signature verification
Tampering	Transaction amount is altered during transmission	Integrity	TLS and cryptographic integrity validation
Repudiation	Fraudulent refund is processed and later denied	Accounting / Possession	Immutable, tamper-evident audit logging
Information Disclosure	Misconfigured storage or database exposes KYC and customer information	Confidentiality	Encryption at rest and least privilege
Denial of Service	Checkout API or merchant portal is overwhelmed by malicious traffic	Availability	WAF, rate limiting, and DDoS protection
Elevation of Privilege	Application vulnerability allows a lower-privileged user to gain administrative access	Authorization	Secure authorization controls and least privilege

5. Spoofing Threat

Threat Scenario

PaySphere integrates with Razorpay for payment processing. An attacker could attempt to impersonate Razorpay by sending a fraudulent webhook to the PaySphere merchant portal.

For example, a malicious actor could send a request claiming that:

- A payment was successfully completed.
- A payment failed.
- A refund was processed.
- A transaction status changed.

If PaySphere processes the request without verifying that it genuinely originated from Razorpay, the attacker may be able to manipulate transaction processing or trigger unauthorized actions.

Security Pillar Impacted

Authenticity

The primary security concern is determining whether the system communicating with PaySphere is genuinely the system it claims to be.

The webhook must be verified as originating from the legitimate payment gateway rather than an attacker impersonating it.

Primary Control

Cryptographic Webhook Signature Verification

PaySphere should verify the cryptographic signature associated with incoming webhooks before processing them.

The application should validate that:

- The request was signed using the expected secret or cryptographic mechanism.
- The signature is valid.
- The message has not been modified.
- The request genuinely originates from the trusted payment integration.

Supporting Controls

Additional controls may include:

- Secure TLS communication.
- Secure management of webhook secrets.
- Monitoring for abnormal webhook activity.
- Validation of request formats.
- Detection of repeated or suspicious requests.

GRC Perspective

This threat demonstrates that authentication is not limited to human users.

Systems communicating with each other must also establish and verify authenticity. From a GRC perspective, evidence may be required to demonstrate that external integrations have appropriate authentication and verification mechanisms.

6. Tampering Threat

Threat Scenario

An attacker attempts to alter transaction information while it is transmitted between PaySphere systems or between PaySphere and an external payment provider.

A realistic example would be an attacker attempting to modify a transaction amount before the information reaches its intended destination.

For example:

A transaction initiated for one amount is maliciously altered during transmission before being processed by another system.

Security Pillar Impacted

Integrity

Financial transaction information must remain accurate and unchanged throughout processing.

Even if an attacker cannot read sensitive transaction information, unauthorized modification can result in financial loss, inaccurate records, and incorrect settlements.

Primary Controls

Transport Layer Security

TLS should be used to protect data while it is transmitted between systems.

TLS helps protect against unauthorized interception and manipulation of communications.

Cryptographic Integrity Verification

Cryptographic integrity mechanisms should also be used where appropriate to verify that data received by the destination matches the information originally sent.

This can help detect unauthorized modification of messages or transaction data.

GRC Perspective

This scenario demonstrates that protecting data confidentiality is not sufficient for financial systems.

A transaction can remain confidential but still create significant risk if its amount, destination, or processing status can be altered.

Integrity controls therefore play a critical role in payment environments.

7. Repudiation Threat

Threat Scenario

A vendor employee or internal PaySphere employee processes a fraudulent refund and later denies performing the action.

If sufficient records are unavailable, PaySphere may be unable to establish:

- Who performed the action.
- When the action occurred.
- Which account initiated it.
- What transaction was affected.
- Whether authorization existed.

Security Pillar Impacted

Accounting / Possession

The primary concern is accountability.

The organization must be able to reliably establish evidence of important actions performed within the system.

Primary Control

Immutable and Tamper-Evident Audit Logging

PaySphere should maintain comprehensive audit logs for important system and transaction events.

These should include:

- Refund processing.
- Transaction modifications.

- Privileged actions.
- Authentication events.
- Authorization failures.
- Access to sensitive systems.
- Administrative changes.

The logs should be protected against unauthorized modification or deletion.

Ideally, logs should be transmitted to a separate logging environment where the individual performing an action cannot alter or delete the evidence.

Why Standard Logging Is Not Enough

Simply maintaining logs is not sufficient to address repudiation.

If a privileged user can:

- Modify logs.
- Delete logs.
- Disable logging.
- Remove evidence of an action.

then the logging system does not provide reliable accountability.

The logging mechanism must therefore provide tamper resistance or tamper evidence.

GRC Perspective

Audit logging is both a security and compliance requirement.

From a GRC perspective, the organization may need to demonstrate:

- That logging is enabled.
- That important actions are captured.
- That logs are retained.
- That logs are protected from unauthorized modification.
- That relevant events can be reviewed during investigations.

8. Information Disclosure Threat

Threat Scenario

Sensitive customer information is exposed because of a misconfigured storage service, database, or web server.

A realistic scenario could involve:

- A publicly accessible storage location containing KYC documents.
- A misconfigured database exposing customer information.
- Excessive user permissions.
- An application configuration exposing sensitive records.

The exposed information could include:

- KYC documentation.
- Personally identifiable information.
- Customer records.
- Merchant information.
- Payment-related data.

Security Pillar Impacted

Confidentiality

Sensitive information should only be accessible to authorized users and systems.

Primary Controls

Encryption at Rest

Sensitive data should be encrypted while stored.

Encryption helps protect the information even if unauthorized access to the underlying storage occurs.

Least Privilege

Users and systems should only receive access necessary to perform their legitimate responsibilities.

For example:

- Support personnel should not receive unrestricted access to sensitive customer data.
- Administrative access should be restricted.
- Access should be based on legitimate business requirements.

Supporting Controls

Additional measures include:

- Secure configuration baselines.
- Configuration monitoring.
- Periodic access reviews.

- Vulnerability assessments.
- Penetration testing.
- Monitoring for unauthorized access.

GRC Perspective

Information disclosure demonstrates the importance of layered controls.

Encryption protects the data itself, while access controls and configuration management reduce the likelihood of unauthorized exposure occurring.

A mature control environment therefore includes both:

Preventive controls to reduce exposure and protective controls to reduce impact.

9. Denial of Service Threat

Threat Scenario

An attacker launches a Denial of Service or Distributed Denial of Service attack against the PaySphere merchant portal or checkout API.

The attacker may generate a large volume of malicious requests designed to:

- Overwhelm application resources.
- Exhaust server capacity.
- Consume network bandwidth.
- Prevent legitimate transactions from being processed.

The impact could include merchants being unable to access the portal or customers being unable to complete transactions.

Security Pillar Impacted

Availability

Critical payment and merchant services must remain available to legitimate users.

Service outages can directly affect:

- Revenue.
- Merchant operations.
- Customer experience.
- Transaction processing.
- Business reputation.

Primary Controls

Web Application Firewall

A WAF can help identify and block malicious application-layer requests.

Rate Limiting

Rate limiting can restrict excessive requests and reduce the impact of automated or abusive traffic.

Dedicated DDoS Protection

Large-scale volumetric attacks may require dedicated DDoS protection or CDN-based traffic absorption capabilities.

Supporting Controls

Additional resilience measures may include:

- Load balancing.
- Redundant infrastructure.
- Incident response procedures.
- Disaster recovery planning.
- Capacity monitoring.

GRC Perspective

This scenario demonstrates the difference between preventing an attack and recovering from one.

A WAF and DDoS protection help address malicious traffic in real time.

Business continuity and disaster recovery measures help reduce the operational impact if an attack successfully disrupts the service.

Both are important, but they address different stages of the risk lifecycle.

10. Elevation of Privilege Threat

Threat Scenario

A vulnerability within the PaySphere merchant portal allows a lower-privileged user to gain permissions beyond their authorized role.

For example:

A support employee exploits an authorization flaw and gains administrative or database-level privileges.

This could provide unauthorized access to sensitive systems or information.

Security Pillar Impacted

Authorization

Users should only be able to perform actions associated with their approved permissions.

Primary Controls

Secure Development Practices

Secure coding and vulnerability management should help prevent authorization flaws from being introduced into the application.

Role-Based Access Control

Access should be assigned based on defined roles.

For example:

- Support employees receive support-related access.
- Database administrators receive database access.
- Administrative privileges remain restricted.

Least Privilege

Users should receive the minimum access necessary to perform their responsibilities.

Separation of Duties

Critical actions should not depend entirely on one individual having unrestricted control.

Access Logging and Monitoring

Privilege changes and suspicious access patterns should be logged and monitored.

Zero Trust Principles

Access should not automatically be trusted simply because a user is already inside a corporate environment.

Sensitive requests should be evaluated using relevant context and authorization requirements.

Layered Control Approach

This threat can be addressed through multiple layers:

Preventive

- Secure coding.
- RBAC.
- Least privilege.

Detective

- Access logging.
- Privilege monitoring.
- Detection of abnormal activity.

Continuous Verification

- Zero Trust principles.
- Context-aware authorization.
- Reduced reliance on standing trust.

GRC Perspective

This threat demonstrates the importance of selecting controls based on the risk being addressed.

Zero Trust can provide an important architectural layer, but it should not replace fundamental controls such as secure authorization logic, RBAC, and least privilege.

Part B — Compliance Automation Control Mapping

11. Project Objective

The second part of this project examines how security controls could be represented inside a compliance automation platform.

Platforms such as compliance automation tools typically help organizations:

- Maintain a control library.
- Collect evidence.
- Connect to technical systems.
- Monitor control status.

- Identify control failures.
- Track remediation activities.
- Prepare evidence for audits and compliance assessments.

For this project, two controls were selected:

1. Multi-Factor Authentication.
2. Periodic Access Reviews.

The purpose was not to configure an actual platform but to analyze how these controls would logically be represented and evidenced.

12. Control 1 — Multi-Factor Authentication

Control Objective

Ensure that users accessing sensitive systems must provide more than one authentication factor.

For PaySphere, MFA would be particularly important for:

- Privileged accounts.
 - Cloud environments.
 - Administrative systems.
 - Production environments.
 - Sensitive business applications.
-

Expected Representation in a Compliance Automation Platform

MFA would likely be represented as a technical control connected directly to an organization's identity provider, cloud environment, or authentication system.

The compliance platform could use integrations or APIs to determine whether applicable users have MFA enabled.

Evidence the Platform Could Collect

Potential evidence includes:

- API-collected MFA configuration.
- User MFA enrollment status.
- Lists of privileged accounts.
- Authentication policy settings.
- Identification of users without MFA.
- Security configuration reports.
- Screenshots or exported configuration evidence where APIs are unavailable.

The strongest evidence would generally be automatically collected configuration data directly from the integrated system.

Evidence Type

Primarily Automated Technical Evidence

Example:

Configuration data confirms that privileged users are required to use MFA when accessing the organization's cloud environment.

Monitoring Frequency

Continuous or Recurring

MFA should not be treated as a one-time control.

A previously compliant environment can become non-compliant if:

- A user disables MFA.
- A privileged account is created without MFA.
- An authentication policy is changed.
- A user receives an inappropriate exemption.

Therefore, the control should ideally be monitored continuously or evaluated regularly through automated integrations.

Example Control Structure

Control Component	Representation
Control	MFA required for privileged access
Evidence Source	Cloud environment or identity provider

Control Component	Representation
Evidence	API-collected MFA configuration
Testing Method	Automated technical validation
Frequency	Continuous or recurring
Failure Condition	Privileged account exists without MFA
Remediation	Enable MFA or remove unnecessary access

13. Control 2 — Periodic Access Reviews

Control Objective

Ensure that users retain access only when that access remains necessary for their job responsibilities.

Access reviews are particularly important in environments where excessive or standing privileged access creates significant risk.

Expected Representation in a Compliance Automation Platform

Unlike MFA, access reviews are not always purely technical configuration checks.

A compliance automation platform could:

1. Automatically collect user and access information.
 2. Identify users and permissions requiring review.
 3. Generate a review workflow.
 4. Assign the review to a manager or system owner.
 5. Record approval, rejection, or access-removal decisions.
 6. Retain the completed review as audit evidence.
-

Evidence the Platform Could Collect

Potential evidence includes:

- Lists of users.
- Assigned roles.
- Privileged account inventories.
- Permissions.
- Dates of last access.

- Access review records.
- Reviewer approvals.
- Completion timestamps.
- Records of access revocation.

The platform can collect much of the technical data automatically, but determining whether access is still required may require human judgment.

Evidence Type

Hybrid: Automated Evidence + Human Attestation

For example:

The platform automatically collects the list of users with privileged access and presents it to the designated system owner for review and certification.

The system owner then confirms:

- Access is still required.
 - Access should be modified.
 - Access should be removed.
-

Monitoring Frequency

Recurring

Access reviews should be performed according to a defined schedule.

Examples may include:

- Quarterly privileged access reviews.
- Periodic standard user access reviews.
- Reviews triggered by role changes.
- Reviews triggered by employee departures.

The review frequency should be aligned with the sensitivity and risk associated with the access.

Example Control Structure

Control Component	Representation
Control	Periodic review of user and privileged access
Evidence Source	Identity systems, cloud platforms, and applications
Evidence	User lists, permissions, approvals, revocation records
Testing Method	Automated evidence collection plus human review
Frequency	Recurring
Failure Condition	Review incomplete or unnecessary access remains active
Remediation	Complete review and revoke unnecessary access

14. Control Comparison

Control	Evidence Collection	Automation Level	Monitoring Frequency
Multi-Factor Authentication	System configuration and MFA enrollment status	Highly automated	Continuous or recurring
Access Reviews	User access data, reviewer decisions, approval records	Hybrid	Recurring

15. Key GRC Insight: Automation Does Not Eliminate Human Judgment

One of the key outcomes of this exercise is the recognition that different controls have different levels of automation.

Some controls are primarily technical.

For example:

Is MFA enabled?

This can often be answered automatically by examining system configuration.

Other controls require a business decision.

For example:

Does this employee still need access to this sensitive system?

A platform can automatically collect the access data, but a manager or system owner may still need to make the final decision.

Therefore, compliance automation should be understood as:

Automation of evidence collection, control monitoring, and workflow management — not necessarily the complete automation of every security decision.

16. Key Learning Outcomes

Through this project, the following concepts were applied in a practical context.

Threat Modeling

- Applied the STRIDE framework to a realistic financial technology environment.
- Identified threats across all six STRIDE categories.
- Connected technical threats to the security properties they affect.

CIA Triad and Parkerian Concepts

- Confidentiality was applied to customer and KYC information.
- Integrity was applied to transaction information.
- Availability was applied to payment and checkout services.
- Authenticity was applied to external system communication.
- Accounting and possession concepts were applied to accountability and audit evidence.
- Authorization was applied to privilege escalation scenarios.

Security Control Selection

- Selected controls based on the specific nature of each threat.
- Distinguished primary controls from supporting controls.
- Applied preventive controls.
- Applied detective controls.
- Applied continuous verification concepts.

Identity and Access Management

- Applied authentication and authorization principles.
- Used Role-Based Access Control.
- Applied least privilege.
- Applied Separation of Duties.
- Recognized the importance of access logging.
- Considered Zero Trust as an architectural verification layer.

GRC and Compliance Automation

- Examined how controls can be translated into evidence requirements.
- Distinguished between automated evidence and human attestation.

- Identified continuously monitored controls.
 - Identified periodically recurring controls.
 - Considered how compliance automation platforms support control monitoring and audit readiness.
-

17. Final Conclusion

This project demonstrates the transition from understanding individual cybersecurity concepts to applying them within a realistic business and GRC environment.

The STRIDE assessment identified six distinct threats against the PaySphere merchant portal:

- Spoofing.
- Tampering.
- Repudiation.
- Information Disclosure.
- Denial of Service.
- Elevation of Privilege.

Each threat was connected to the security property most directly affected and paired with an appropriate control strategy.

The compliance automation exercise extended the analysis beyond control design by considering how controls are demonstrated, monitored, and evidenced within an organization.

The two selected controls highlighted an important distinction:

- **MFA** represents a highly automatable technical control that can be validated through system integrations.
- **Access reviews** represent a hybrid control where automation can collect evidence, but human reviewers are required to make access decisions.

Together, these exercises demonstrate an end-to-end approach to security and GRC:

Identify the system and assets → Understand threats → Determine security impact → Select appropriate controls → Collect evidence → Monitor control effectiveness → Identify and remediate control failures

This approach represents a practical foundation for GRC activities involving security risk assessment, control evaluation, evidence collection, compliance monitoring, and security automation.

Portfolio Skills Demonstrated

STRIDE Threat Modeling
CIA Triad
Parkerian Hexad
Security Control Design
Risk-Based Thinking
Identity and Access Management
Authentication and Authorization
Role-Based Access Control (RBAC)
Least Privilege
Separation of Duties (SoD)
Audit Logging and Accountability
Defense in Depth
Zero Trust Concepts
Compliance Evidence Collection
Continuous Control Monitoring
Periodic Control Testing
GRC Automation Concepts

Project Deliverable

Week 2 successfully demonstrates the ability to analyze a business-critical system from both a cybersecurity and GRC perspective, moving from threat identification through security control selection and into compliance evidence and control monitoring.

Final Deliverables Completed:

- ✓ STRIDE Threat Model for PaySphere Merchant Portal
- ✓ Six realistic security threats identified
- ✓ CIA/Parkerian security properties mapped
- ✓ Appropriate controls identified
- ✓ MFA mapped to compliance automation evidence collection
- ✓ Access reviews mapped to compliance automation evidence collection
- ✓ Continuous vs. recurring control monitoring analyzed
- ✓ GRC workflow and learning outcomes documented